

RELATÓRIO DE REVISÃO

Regras de negócio e compliance

Controles técnicos, lacunas organizacionais e critérios para implantação municipal

Cuidado simples para quem precisa. Gestão clara para quem atende.

Medicamentos, agendamentos, especialidades e comunicação em uma experiência inclusiva e rastreável.

Versão demonstrativa • Prefeitura de Altair/SP

1. Parecer executivo

Conclusão

O MVP está tecnicamente mais seguro e coerente após a revisão, mas não deve ser apresentado como produto juridicamente certificado. A conformidade final exige controles técnicos e também decisões formais do Município de Altair/SP.

Foram revisados portal público, autenticação, jornada do cidadão, solicitação e dispensação de medicamentos, estoque/lotes, agendas, especialistas, usuários administrativos, documentos, privacidade, auditoria, dependências e mensagens de interface. Os dados permanecem fictícios.

Dimensão	Situação após correções	Condição para produção
Transparência de estoque	Pronto tecnicamente	Rotina municipal que garanta conferência e atualização em até 15 dias.
Regras de medicamentos	Fluxo corrigido	Validação farmacêutica, protocolos locais e responsáveis definidos.
LGPD e dados de saúde	Controles técnicos parciais	Encarregado, bases legais, inventário, retenção, RIPD e contratos.
Segurança	Controles essenciais aplicados	Pentest, monitoramento, backup, continuidade e resposta a incidentes.
Acessibilidade	Base semântica e mobile	Auditoria eMAG/WCAG, testes por teclado/leitor e com usuários.
Demonstração pública	Segura para dados fictícios	Não inserir dados reais no ambiente demonstrativo.

2. Correções implementadas

Risco encontrado	Correção aplicada	Resultado esperado
Reserva duplicada	Transição recebida → aprovada validada e reserva atômica.	Repetir a aprovação não duplica saldo reservado.
Lote errado na conclusão	Pedido guarda reserved_lot_id e consome exatamente esse lote.	Rastreabilidade entre cidadão, protocolo, lote e saída.
Estados pulados	Máquina de estados para pedido e consulta.	Não é possível concluir antes de aprovar e preparar.
Recusa sem justificativa	Motivo obrigatório, aviso ao cidadão e liberação de recursos.	Decisão explicável e fila/estoque consistentes.
Concorrência no horário	Trigger de banco valida capacidade e incrementa reserva no INSERT.	Duas solicitações simultâneas não ultrapassam a capacidade.

Risco encontrado	Correção aplicada	Resultado esperado
Entrega liberada cedo	Validação documental e primeira retirada são etapas independentes.	Entrega somente após ambas concluídas.
Upload permissivo	Allowlist PDF/JPG/PNG, limite de 5 MB e assinatura mágica.	Redução de arquivo disfarçado e carga excessiva.
Tentativas ilimitadas	Bloqueio por identidade após cinco falhas durante 15 minutos.	Mitigação de força bruta.
Perfis sem separação	RBAC: operador, gestor e administrador geral.	Privilegio mínimo por função.
Sem canal LGPD	Pedidos de acesso, correção, informação e revisão.	Demanda do titular registrada e acompanhável.
Data de estoque artificial	Portal usa a última atualização real dos lotes.	Transparência verificável.
Dependências vulneráveis	Next atualizado e auditoria de produção zerada.	0 vulnerabilidades conhecidas no npm audit --omit=dev em 15/08/2026.

3. Regras de negócio consolidadas

Cadastro, ativação e entrega

- Ativação: CPF, data de nascimento, código vigente e senha com dez ou mais caracteres, contendo letras e números.
- CPF é usado normalizado e armazenado como hash; somente a versão mascarada aparece nas telas administrativas.
- Código de ativação é de uso único e possui validade; um novo código revoga o anterior.
- Validar documentos não elimina a obrigação da primeira retirada presencial.
- Entrega domiciliar exige cadastro validado, primeira retirada concluída, produto elegível e faixa com pelo menos 24 horas de antecedência.

Solicitação e dispensação

Estado atual	Próximos estados permitidos	Efeito
Recebida	Aprovada ou não aprovada	Ocupa horário; aguarda análise.
Aprovada	Pronta/programada ou não aprovada	Reserva lote FEFO específico.
Pronta/programada	Concluída ou não aprovada	Aguarda retirada/entrega.
Concluída	Nenhum	Baixa física e reservada no lote vinculado.
Não aprovada	Nenhum	Registra motivo e libera horário/reserva futura.

- Receita é obrigatória quando o cadastro do produto assim definir.
- O saldo público não constitui promessa de dispensação; cadastro, receita, quantidade e lote são conferidos.
- Lotes vencidos não podem ser escolhidos na aprovação.
- Sem saldo, o cidadão registra uma necessidade única por medicamento e recebe aviso quando uma nova entrada torna o item disponível.

Agenda de especialistas

- A manifestação é uma intenção para planejamento; não é encaminhamento, regulação ou consulta confirmada.
- Uma intenção ativa por cidadão e especialidade evita contagem duplicada.
- A agenda usa somente local cadastrado e ativo, data futura e capacidade entre 1 e 500.
- Confirmação do cidadão é aceita somente em agenda confirmada, futura e com vaga.
- Consulta planejada pode ser confirmada ou cancelada; confirmada pode ser concluída ou cancelada; estados finais não reabrem automaticamente.

4. Matriz de conformidade

Referência	Exigência aplicada ao produto	Avaliação
Lei 14.654/2023	Estoque das farmácias públicas em página eletrônica, acessível ao cidadão comum e atualizado ao menos quinzenalmente.	Atendido tecnicamente; governança da atualização é municipal.
LGPD, arts. 5º, 7º, 11 e 23	Saúde é dado sensível; tratamento público requer finalidade, base legal, transparência e necessidade.	Parcial: minimização e canal implementados; atos e inventário pendentes.
LGPD, arts. 37, 41, 46, 48 e 50	Registros, encarregado, segurança, incidentes e governança.	Parcial: auditoria e segurança aplicadas; programa formal pendente.
Resolução CD/ANPD 15/2024	Processo para avaliar e comunicar incidentes de segurança.	Pendente organizacional: plano, responsáveis e simulado.
Lei 13.146/2015, art. 63	Acessibilidade obrigatória em sítios de órgãos de governo.	Parcial: semântica e responsividade; homologação assistiva pendente.
eMAG 3.1 / WCAG	Padrões Web, teclado, labels, instruções, contraste e avaliação.	Parcial: vários fundamentos presentes; auditoria completa pendente.

Sem certificação automática

Nenhum teste de software substitui parecer jurídico, farmacêutico, de segurança ou acessibilidade. Este relatório classifica prontidão técnica e tarefas de implantação.

5. LGPD: mapa de dados e finalidades

Dados	Finalidade	Proteção/observação
CPF e nascimento	Identificar e ativar o cidadão.	CPF com hash e máscara; restringir consulta bruta.
Endereço/bairro	Cadastro e entrega domiciliar.	Usar somente quando necessário; definir retenção.
Receitas/documentos	Validar direito à dispensação e identidade.	Armazenamento privado, allowlist e acesso restrito.
Medicamentos e pedidos	Atender política pública de assistência farmacêutica.	Dado de saúde sensível; auditoria e mínimo acesso.
Interesse em especialista	Planejar oferta municipal.	Não expor demanda individual no portal público.
Mensagens e avisos	Comunicação operacional.	Orientar equipe a evitar dados desnecessários.
Logs de auditoria	Segurança, responsabilização e controle.	Definir retenção, acesso e proteção contra alteração.

6. Ações obrigatórias antes do go-live

1. Nomear/publicar controlador e contato do encarregado; definir canal alternativo presencial/telefônico.
2. Registrar operações, finalidades, categorias, bases legais, compartilhamentos e prazos de retenção.
3. Elaborar RIPD para o tratamento de dados sensíveis e riscos de entrega/integração, quando indicado.
4. Formalizar contrato de operador/suboperadores, hospedagem, localização dos dados, descarte e auditoria.
5. Configurar domínio oficial, TLS, segredos, banco/R2 de produção e ambientes separados de teste.
6. Testar backup/restauração, continuidade, monitoramento, alertas e resposta a incidentes conforme RCIS.
7. Executar pentest independente e corrigir achados críticos/altos antes de dados reais.
8. Realizar auditoria eMAG/WCAG, navegação por teclado, leitor de tela, contraste, zoom e teste com cidadãos idosos e com deficiência.

9. Definir protocolo farmacêutico: receita, quantidade, substituição, controlados, cadeia fria, entrega e comprovação.
10. Treinar operadores e gestores em LGPD, engenharia social, arquivos, atendimento e contingência.

7. Critérios de aceite do piloto

Teste	Critério de aprovação
Estoque público	Data real, escopo da unidade e atualização monitorada em até 15 dias.
Concorrência	Capacidade nunca excedida em solicitações simultâneas.
Lote	Reserva e baixa usam o mesmo lote; saldo físico/reservado permanece não negativo.
Privacidade	Operador não acessa auditoria/fila LGPD; cidadão vê somente os próprios dados.
Arquivos	Formato disfarçado, arquivo >5 MB e extensão não permitida são bloqueados.
Acessibilidade	Fluxos críticos completos por teclado e leitor de tela, sem perda a 200% de zoom.
Incidente	Equipe executa simulado, classifica risco e aciona responsáveis dentro do procedimento.
Continuidade	Restauração comprovada com RPO/RTO aprovados pelo município.

8. Referências oficiais

- Lei nº 14.654/2023: https://www.planalto.gov.br/ccivil_03/_ato2023-2026/2023/lei/l14654.htm
- Lei Geral de Proteção de Dados (Lei nº 13.709/2018): https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709compilado.htm
- Guia ANPD - Tratamento de dados pessoais pelo Poder Público: https://www.gov.br/anpd/pt-br/centrais-de-conteudo/materiais-educativos-e-publicacoes/guia_tratamento_de_dados_pessoais_pelo_poder_publico_defeso_eleitoral.pdf
- Resolução CD/ANPD nº 15/2024: <https://www.gov.br/anpd/pt-br/assuntos/noticias/anpd-aprova-o-regulamento-de-comunicacao-de-incidente-de-seguranca>
- Lei Brasileira de Inclusão (Lei nº 13.146/2015): https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2015/lei/l13146.htm
- Modelo de Acessibilidade em Governo Eletrônico (eMAG): <https://www.gov.br/governodigital/pt-br/acessibilidade-e-usuario/acessibilidade-digital/modelo-de-acessibilidade>